

UNIT-II

Vulnerabilities

Vulnerability

A vulnerability is a weakness that can be exploited by cybercriminals to gain unauthorized access to a computer system. After exploiting a vulnerability, a cyberattack can run malicious code, install malware, and even steal sensitive data.

Vulnerabilities can be exploited by a variety of methods, including SQL injection, buffer overflows, cross-site scripting (XSS), and open-source exploit kits that look for known vulnerabilities and security weaknesses in web applications.

Many vulnerabilities impact popular software, placing the many customers using the software at a heightened risk of a data breach, or supply chain attack. Such zero-day exploits are registered by MITRE as a Common Vulnerability Exposure (CVE).

Vulnerability Examples

There are several different types of vulnerabilities, determined by which infrastructure they're found on. Vulnerabilities can be classified into six broad categories:

1. Hardware

Any susceptibility to humidity, dust, soiling, natural disaster, poor encryption, or firmware vulnerability.

2. Software

Insufficient testing, lack of audit trail, design flaws, memory safety violations (buffer overflows, over-reads, dangling pointers), input validation errors (code injection, cross-site scripting (XSS), directory traversal, email injection, format string attacks, HTTP header injection, HTTP response splitting, SQL injection), privilege-confusion bugs (clickjacking, cross-site request forgery, FTP bounce attack), race conditions (symlink races, time-of-check-to-time-of-use bugs), side channel attacks, timing attacks and user interface failures (blaming the victim, race conditions, warning fatigue).

3. Network

Unprotected communication lines, man-in-the-middle attacks, insecure network architecture, lack of authentication, default authentication, or other poor network security.

4. Personnel

Poor recruiting policy, lack of security awareness and training, poor adherence to security training, poor password management, or downloading malware via email attachments.

5. Physical site

Area subject to natural disaster, unreliable power source, or no key card access.

6. Organizational

Improper internal controls, lack of audit, continuity plan, security, or incident response plan.

When Should Known Vulnerabilities Be Publicly Disclosed?

Whether to publicly disclose known vulnerabilities remains a contentious issue. There are two options:

1. Immediate Full Disclosure

Some cybersecurity experts argue for immediate disclosure, including specific information about how to exploit the vulnerability. Supporters of immediate disclosure believe it leads to secure software and faster patching improving software security, application security, computer security, operating system security, and information security.

2. Limited to No Disclosure

Others are against vulnerability disclosure because they believe the vulnerability will be exploited by hackers. Supporters of limited disclosure believe limiting information to select groups reduces the risk of exploitation.

Like most arguments, there are valid arguments from both sides.

Regardless of which side you fall on, know that it's now common for friendly attackers and cyber criminals to regularly search for vulnerabilities and test known exploits.

Some companies have in-house security teams whose job it is to test IT security and other security measures of the organization as part of their overall information risk management and cyber security risk assessment process.

Best-in-class companies offer bug bounties to encourage anyone to find and report vulnerabilities to them rather than exploiting them. Bug bounty programs are great and can help minimize the risk of your organization joining our list of the biggest data breaches.

Typically, the payment amount of a bug bounty program will be commensurate with the size of the organization, the difficulty of exploiting the vulnerability, and the impact of the vulnerability. For example, finding a data leak of personally identifiable information (PII) of a Fortune 500 company with a bug bounty program would be of higher value than a data breach of your local corner store.

What is the Difference Between Vulnerability and Risk?

Cyber security risks are commonly classified as vulnerabilities. However, vulnerability and risk are not the same thing, which can lead to confusion.

Think of risk as the probability and impact of a vulnerability being exploited.

If the impact and probability of a vulnerability being exploited is low, then there is low risk. Inversely, if the impact and probability of a vulnerability being exploited is high, then there is a high risk.

Generally, the impact of a cyber-attack can be tied to the CIA triad or the confidentiality, integrity, or availability of the resource. Following this train of reasoning, there are cases where common vulnerabilities pose no risk. For example, when the information system with the vulnerability has no value to your organization.

When Does a Vulnerability Become an Exploitable?

A vulnerability with at least one known, working attack vector is classified as an exploitable vulnerability. The window of vulnerability is the time from when the vulnerability was introduced to when it is patched.

If you have strong security practices, then many vulnerabilities are not exploitable for your organization.

For example, if you have properly configured S3 security, then the probability of leaking data is lowered. Check your S3 permissions, or someone else will.

Likewise, you can reduce third-party risk and fourth-party risk with third-party risk management and vendor risk management strategies.

What is a Zero-Day Exploit?

A zero-day exploit (or zero-day) exploits a zero-day vulnerability. A zero-day (or 0-day) vulnerability is a vulnerability that is unknown to, or unaddressed by, those who want to patch the vulnerability.

Until the vulnerability is patched, attackers can exploit it to adversely affect a computer program, data warehouse, computer or network.

"Day Zero" is the day when the interested party learns of the vulnerability, leading to a patch or workaround to avoid exploitation.

The key thing to understand is the fewer days since Day Zero, the higher likelihood that no patch or mitigation has been developed and the higher the risk of a successful attack.

What Causes Vulnerabilities?

There are many causes of vulnerabilities, including:

Complexity

Complex systems increase the probability of a flaw, misconfiguration, or unintended access.

Familiarity

Common code, software, operating systems, and hardware increase the probability that an attacker can find or has information about known vulnerabilities.

Connectivity

The more connected a device is, the higher the chance of a vulnerability.

Poor Password Management

Weak passwords can be broken with brute force, and reusing passwords can result in one data breach becoming many.

Operating System Flaws

Like any software, operating systems can have flaws. Operating systems that are insecure by default allow any user to gain access and potentially inject viruses and malware.

Internet Usage

The Internet is full of spyware and adware that can be installed automatically on computers.

Software Bugs

Programmers can accidentally or deliberately leave an exploitable bug in software. Sometimes end users fail to update their software, leaving them unpatched and vulnerable to exploitation.

Unchecked User Input

If your website or software assumes all input is safe, it may execute unintended SQL commands.

People

The biggest vulnerability in any organization is the human at the end of the system. Social engineering is the biggest threat to the majority of organizations.

What is Vulnerability Management?

Vulnerability management is a cyclical practice of identifying, classifying, remediating, and mitigating security vulnerabilities. The essential elements of vulnerability management include vulnerability detection, vulnerability assessment, and remediation.

Methods of vulnerability detection include:

Vulnerability scanning

Penetration testing

Google hacking

Once a vulnerability is found, it goes through the vulnerability assessment process:

1. Identify Vulnerabilities

Analysing network scans, pen test results, firewall logs, and vulnerability scan results to find anomalies that suggest a cyber-attack could take advantage of a vulnerability.

2. Verify Vulnerabilities

Decide whether the identified vulnerability could be exploited and classify the severity of the exploit to understand the level of risk.

3. Mitigate Vulnerabilities

Decide on countermeasures and how to measure their effectiveness if a patch is unavailable.

4. Remediate Vulnerabilities

Remediating vulnerabilities requires updating affected software or hardware where possible. Since cyber-attacks are constantly evolving, vulnerability management must be a continuous and repetitive practice to ensure your organization remains protected.

What is Vulnerability Scanning?

A vulnerability scanner is software designed to assess computers, networks or applications for known vulnerabilities. They can identify and detect vulnerabilities rising from misconfiguration and flawed programming within a network and perform authenticated and unauthenticated scans:

Authenticated scans: Allows the vulnerability scanner to directly access networked assets using remote administrative protocols like secure shell (SSH) or remote desktop protocol (RDP) and authenticate using provided system credentials. This gives access to low-level data such as specific services and configuration details, providing detailed and accurate information about operating systems, installed software, configuration issues, and missing security patches.

Unauthenticated scans: Result in false positives and unreliable information about operating systems and installed software. This method is generally used by cyber attackers and security analysts to try and determine the security posture of externally facing assets and to find possible data leaks.

What is Penetration Testing?

Penetration testing, also known as pen testing or ethical hacking, is the practice of testing an information technology asset to find security vulnerabilities an attacker could exploit. Penetration testing can be automated with software or performed manually.

Either way, the process is to gather information about the target, identify possible vulnerabilities and attempt to exploit them, and report on the findings.

Penetration testing may also be used to test an organization's security policy, adherence to compliance requirements, employee security awareness, and an organization's ability to identify and respond to security incidents.

What is Google Hacking?

Google hacking is the use of a search engine, such as Google or Microsoft's Bing, to locate security vulnerabilities. Google hacking is achieved using advanced search operators in queries that locate hard-to-find information or information that is being accidentally exposed through misconfiguration of cloud services.

Security researchers and attackers use these targeted queries to locate sensitive information that is not intended to be exposed to the public.

These vulnerabilities tend to fall into two types:

- Software vulnerabilities
- Misconfigurations

That said, many attackers will tend to search for common user misconfigurations that they already know how to exploit and simply scan for systems that have known security holes.

To prevent Google hacking, you must ensure that all cloud services are properly configured. Once something is exposed to Google, it's public whether you like it or not.

Yes, Google periodically purges its cache, but until then, your sensitive files are being exposed to the public.

What are Vulnerability Databases?

A vulnerability database is a platform that collects, maintains, and shares information about discovered vulnerabilities. MITRE runs one of the largest, called CVE or Common Vulnerabilities and Exposures, and assigns a Common Vulnerability Scoring System (CVSS) score to reflect the potential risk a vulnerability could introduce to your organization.

This central listing of CVEs serves as the foundation for many vulnerability scanners.

The benefit of public vulnerability databases is that it allows organizations to develop, prioritize and execute patches and other mitigations to rectify critical vulnerabilities.

That said, they can also cause additional vulnerabilities to be created from the hastily released patches that fix the first vulnerability but create another.

Common vulnerabilities listed in vulnerability databases include:

Initial deployment failure: Functionality for databases may appear fine, but without rigorous testing, flaws can allow attackers to infiltrate. Poor security controls, weak passwords, or default security settings can lead to sensitive material becoming publicly accessible.

SQL injection: Database attacks are commonly recorded in vulnerability databases.

Misconfiguration: Companies often fail to configure their cloud services correctly, leaving them vulnerable and often publicly accessible.

Inadequate auditing: Without auditing, it's hard to know whether data has been amended or accessed. Vulnerability databases have promulgated the significance of audit tracking as a deterrent of cyber-attacks.

Security vulnerability detection tools, and techniques:

1) SecPod SanerNow



SecPod SanerNow is an advanced vulnerability management solution for vulnerability and patch management.

It goes beyond traditional vulnerability management by scanning vulnerabilities, misconfiguration, etc, and instantly remediates them as well, all in a single unified console. It replaces multiple solutions to simplify and automate your vulnerability management.

- With its fastest 5-min vulnerability scans and its in-built, world's largest vulnerability repository, SanerNow can accurately detect vulnerabilities and other security risks.
- Along with accurate scans, all detected vulnerabilities can be instantly remediated with its integrated patch management module and additional remediation controls.
- Since it's an integrated solution, SanerNow significantly increases your vulnerability management velocity and efficiency as well.
- SanerNow supports network devices, including routers, switches, and more. And it supports all major OSs like Windows, Linux, and macOS for complete security.
- With the prevention of cyberattacks as the focal point, SanerNow ensures maximum safety and robust security for your organization.

2) Invicti (formerly Netsparker)



Invicti is a dead accurate automated scanner that will identify vulnerabilities such as SQL Injection and Cross-site Scripting in web applications and web APIs.

Invicti uniquely verifies the identified vulnerabilities proving they are real and not false positives. Therefore, you do not have to waste hours manually verifying the identified vulnerabilities once a scan is finished. It is available as a Windows software and as an online service.

3) Acunetix



Acunetix is a fully automated web vulnerability scanner that detects and reports on over 4500 web application vulnerabilities including all variants of SQL Injection and XSS.

The Acunetix crawler fully supports HTML5 and JavaScript and Single-page applications, allowing auditing of complex, authenticated applications.

It bakes in advanced Vulnerability Management features right-into its core, prioritizing risks based on data through a single, consolidated view, and integrating the scanner's results into other tools and platforms.

4) Intruder



Intruder is a proactive vulnerability scanner that scans you as soon as new vulnerabilities are released. In addition, it has over 10,000 historic security checks, including for WannaCry, Heartbleed, and SQL Injection. Integrations with Slack and Jira help notify development teams when newly discovered issues need fixing, and AWS integration means you can synchronize your IP addresses to scan.

The Intruder is popular with startups and medium-sized businesses as it makes vulnerability management easier for small teams.

5) SolarWinds Network Vulnerability Detection



SolarWinds provides Network Vulnerability Detection with its Network Configuration Manager. Its network automation capabilities will rapidly deploy firmware updates to network devices.

It has functionalities for monitoring, managing, and protecting network configurations. The tool will simplify and improve network compliance.

Network Configuration Manager provides the alerts for the changes in the configuration. It performs a continuous audit to find out the configurations that are making the device non-compliant. It will let you make configuration backups that will help you with monitoring the configuration changes.

The software can provide the details about the changes made in the configurations and through which login ID these changes are made. It will help with faster disaster recovery. The price for the solution starts at \$3085. It offers a fully functional free trial for 30 days.

6) AppTrana

Company Name: Indus face



AppTrana: Indus face WAS is an automated web application vulnerability scanner that detects, and reports vulnerabilities based on OWASP top 10.

The company is headquartered in India with offices in Bengaluru, Vadodara, Mumbai, Delhi, and San Francisco and their services are used by 1100+ customers across 25+ countries globally.

Features

- New age crawler to scan single page applications.
- Pause and resume feature.
- Additional Manual Penetration testing and publish the report in the same dashboard.
- Proof of concept request to provide evidence of reported vulnerability and eliminate false positive.

- Optional integration with the Indus face WAF to provide instant virtual patching with Zero False positive.
- Ability to automatically expand crawl coverage based on real traffic data from the WAF systems (in case WAF is subscribed and used).
- 24×7 support to discuss remediation guidelines and POC.
- Free trial with a comprehensive single scan and no credit card required.

7) ManageEngine Vulnerability Manager Plus



ManageEngine Vulnerability Manager Plus is a prioritization-focused threat and vulnerability management software offering built-in patch management.

With its integrated console, it allows you to:

- Assess & prioritize exploitable and impactful vulnerabilities with a risk-based vulnerability assessment.
- Automate & customize patches to Windows, macOS, Linux, and over 300 third-party applications.
- Identify zero-day vulnerabilities and implement workarounds before fixes arrive.
- Continually detect & remediate misconfigurations with security configuration management.
- Gain security recommendations to set up your servers in a way that's free from multiple attack variants.
- Audit end-of-life software, peer-to-peer & insecure remote desktop sharing software, and active ports in your network.

8) Astra



Astra Pentest offers a vulnerability assessment tool that packs the intelligence acquired over years of security testing. The vulnerability scanner conducts 3000+ tests ensuring a thorough evaluation of your security strength. It scans for the OWASP top 10 and SANS 25 CVEs will help you comply with ISO 27001, HIPAA, SOC2, and GDPR.

You can view the vulnerability analysis through an interactive dashboard. Assign vulnerabilities to team members, update vulnerability status, and watch compliance status from the same place. The process becomes even easier for you through the integration of the vulnerability scanner with GitLab, GitHub, Slack, and Jira.

Key Features:

- 3000+ tests
- Intuitive dashboard
- Scan behind the logged-in pages
- Continuous scanning through CI/CD integration
- Compliance reporting
- Scan progressive web apps and single page apps.
- Integrate with Slack, Jira, GitHub & CI/CD tools.
- Accurate risk score and potential losses
- Detailed suggestions to fix the vulnerabilities.

Using the vulnerability assessment tool that caters to your specific needs makes a lot of difference. Connect with security experts to find your fit.

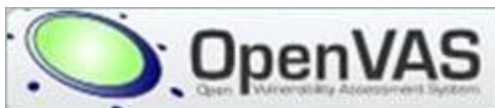
9) Perimeter 81



With Perimeter 81, you get a unified cloud-based platform that can simplify your business's network security processes. The software arms you with cybersecurity tools that allow you to segregate your network into segments to better protect the resources they harbour. The software's intuitive web filtering feature protects your network from all kinds of online threats.

With the addition of features like Zero-trust access, the platform also provides users with a multi-layered security model that puts the onus of security on users instead of perimeters. Moreover, by employing features like 2FA and Single Sign-On, Perimeter 81 makes secure login and user access simple and thus reduces an organization's vulnerability to attacks.

10) OpenVAS



From the name itself, we can come to the conclusion that this tool is an open-source tool. OpenVAS serves as a central service that provides tools for both vulnerability scanning and vulnerability management.

- OpenVAS services are free of cost and are generally licensed under GNU General Public License (GPL)
- OpenVAS supports various operating systems.
- The scan engine of OpenVAS is updated with the Network Vulnerability Tests on a regular basis.
- OpenVAS scanner is a complete vulnerability assessment tool that is used to spot issues related to security in the servers and other devices of the network.

11) Wireshark



Wireshark is the world's leading and extensively used network protocol analyser.

- Wireshark is used across various streams like educational institutions, government agencies, and enterprises to investigate the networks at a microscopic level.
- Wireshark has a special feature like it captures the issues online and performs the analysis offline.
- Wireshark runs on various platforms like Windows, Linux, Mac, and Solaris.
- Wireshark has the capability of deeply inspecting many protocols.
- Among the security practitioner's toolkit, Wireshark is the most powerful tool

12) Nessus Professional



Nessus is a patented and branded vulnerability scanner developed by Tenable Network Security.

- This tool has been installed and used by millions of users throughout the world for vulnerability assessment, configuration issues.
- Nessus is used to prevent the networks from the penetrations made by hackers by assessing the vulnerabilities at the earliest.
- Nessus supports wide range of OS, applications, DBs, and many more network devices among cloud infrastructure, physical and virtual networks
- Nessus can scan the vulnerabilities which allow remote hacking of sensitive data from a system.

Multics Security

The Multics objective to become a "computer utility" led us to a design for a tamper-proof system that allowed users to control the sharing of their files. Although MIT Project MAC was funded by the Advanced Research Projects Agency (ARPA) of the US Department of Defense, ARPA funding did not influence the design of Multics toward features specific to military applications. In the early 60s, J. C. R. Licklider's approach at ARPA's Information Processing Techniques Office (IPTO) was to support general improvements to the state of the computing art. One of the 1965 Multics conference papers, Structure of the Multics Supervisor, stated "Multics does not safeguard against sustained and intelligently conceived espionage, and it is not intended to."

[JHS] Deployment of CTSS brought the discovery that users had a huge appetite to share programs and data with one another. Because of this discovery, Multics was designed to maximize the opportunity for sharing, but with control. The list of security features in Multics is long partly because controlled sharing requires elaborate mechanics.

[DMW] Security was an explicit goal of the Multics design and was continually reviewed as the implementation progressed. System components were designed to use the least level of privilege necessary.

When Multics was made available to users in the early 1970s, it had a large set of security-related features.

- In user mode, the CPU trapped I/O and privileged instructions.
- Memory mapping registers in the CPU supported isolation of and switching between virtual address spaces.
- User programs did not have access to read or write operating system procedures or data.
- User program execution was done in processes with separate virtual address spaces.
- User login required a password.
- Users' files were protected from access by other users unless voluntarily shared.
- The system provided hierarchical administration and resource allocation.
- Each process's virtual address space consisted of multiple segments.
- A segment could be part of more than one address space.
- Each process's address space was defined by a descriptor segment that defined segment access rights.
- Segments had different access permissions depending on the referencing process's descriptor segment.

Concepts of System Security (BTICS601)

- Segments had individual maximum sizes; out of bounds references caused a fault rather than accessing a different segment.
- Segments' accessibility depended on the process's ring of execution.
- In the Multics 6180 CPU architecture, the ring of execution was supported and checked by hardware; current ring number was kept in a CPU register.
- The CPU checked segment access rights and ring brackets on every instruction and generated a fault on unauthorized access.
- The 6180 CPU architecture provided cross-ring pointer checking.
- The operating system's privileged components executed in the most privileged ring.
- Segments were in-memory mappings of files in the file system.
- The file system defined segment accessibility with Access Control Lists (ACLs) and Ring Brackets.
- When segments were made addressable as part of a process's address space, segment descriptor access permissions were derived from the file system ACLs and ring brackets.
- Changes to file system ACLs caused immediate recalculation or revocation of descriptor segment access.
- The system supported inner ring segments with extended access control permissions, such as message segments and mailboxes.
- Standard compiler output was non-writeable code (pure procedure).
- Standard compiler generated code used a stack segment for data; it was non-executable, as was the segment for static data.
- The PL/I string implementation runtime kept track of the declared and allocated sizes of a string.
- The call stack grew from lower addresses to higher, making it less likely that a buffer overrun would damage a return address pointer.
- Each process had a private directory for temporary storage (in >pdd).

Mike Schroeder and Jerry Saltzer described the 6180's ring mechanism in [Schroeder71]. Jerry Saltzer's 1974 paper [Saltzer74] describes the design principles underlying Multics security and ends with a candid description of weaknesses in the Multics protection mechanisms.

Multics developers thought that the combination of our hardware and software architectures, along with careful coding, could provide an adequate solution to the security problem. As mentioned in Saltzer's 1974 paper, we considered Multics to be "securable" at correctly managed installations. As it turned out, we had a long way to go.